HotelSec PolicyForge AI

Informe de ciberseguridad hotelera

Hotel Prueba Lanzarote

Fecha: 13/10/2026 20:44 UTC

Referencia: bcfa15bf-e511-4d62-ae93-4cab9bd46f38

Madurez: 9/100 | Riesgo: Critico

Autodiagnostico basado en declaraciones. Probabilidad e impacto son estimaciones orientativas. Politicas propuestas para revision humana; no certifica ISO ni cumplimiento RGPD. No introduzca documentos, nombres de huespedes ni datos de pago.

Resumen ejecutivo

Hotel Prueba Lanzarote: madurez 9/100. Se detectan 13 riesgos. Priorizar: Implantar copias de seguridad automáticas y mantener al menos una copia aislada. Activar MFA en correo, PMS, paneles de reservas y cuentas administrativas. Crear usuarios individuales para recepción, administración y proveedores. Configurar usuarios individuales y perfiles por rol en el PMS. Separar la red de huéspedes de la red interna mediante VLAN o red independiente.

Resumen: Reglas locales | Politicas: Reglas locales

Version: rules-v2 / hotel-context-v2

Perfil y respuestas declaradas

Campo	Declaracion
Nombre del alojamiento	Hotel Prueba Lanzarote
Municipio	Tías
Tipo de alojamiento	hotel
Habitaciones	42
Empleados fijos	12
Empleados temporales	8
Proveedor IT externo	Si
PMS o channel manager	Si
WiFi para huespedes	Si
Pagos con tarjeta	Si
Documentacion de huespedes	Si
Temporada alta	Todo el ano
Inventario de sistemas	PMS cloud, Microsoft 365, TPV
Categorias de datos	Reservas, facturacion
Conservacion declarada (dias)	180

Campo	Declaracion
Respuesta IT (horas)	24
Doble factor de autenticacion	No
Gestor de contrasenas	No
Cuentas compartidas	Si
Usuarios individuales PMS	No
Retirada de accesos al causar baja	No
Frecuencia de copias	No se realizan
Restauracion probada	No
Antivirus o EDR	Si
Sistemas actualizados	No
Red de huespedes separada	No
TPV aislado	No
CCTV, domotica o IoT	Si
IoT en red separada	No
Acceso remoto de proveedores	Si
Acceso de proveedores controlado	No
Plan de respuesta a incidentes	No
Protocolo de brechas RGPD	No
Registro de tratamientos	No
Formacion contra phishing	No
Politica de contrasenas	No evaluado
Firewall configurado	No evaluado
Contratos con proveedores	No evaluado
Plazos de conservacion definidos	No evaluado
Dispositivos personales	No evaluado
Normas de teletrabajo	No evaluado
Mensajeria segura	No evaluado
Plan de continuidad	No
Check-in manual de emergencia	No evaluado
Responsable de incidentes	No evaluado
Formacion de temporales	No evaluado
Operacion sin conexion	No evaluado

Puntuaciones por area

Identidad y accesos: 0/100

Copias de seguridad: 0/100

Protección de dispositivos: 50/100

Seguridad de red y sistemas hoteleros: 0/100

Proveedores y accesos remotos: 0/100

Respuesta a incidentes: 0/100

Concienciación del personal: 20/100

Continuidad del negocio: 0/100

Mapa de riesgos

Ausencia de copias de seguridad

Prioridad Critico | Probabilidad 4/5 | Impacto 5/5

Un incidente de ransomware, borrado accidental o fallo técnico podría provocar pérdida de reservas, facturación o documentación de clientes.

Implantar copias de seguridad automáticas y mantener al menos una copia aislada.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Falta de doble factor de autenticación

Prioridad Alto | Probabilidad 4/5 | Impacto 4/5

Las cuentas críticas del hotel podrían quedar expuestas si una contraseña se filtra o se reutiliza en otro servicio.

Activar MFA en correo, PMS, paneles de reservas y cuentas administrativas.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Uso de cuentas compartidas

Prioridad Alto | Probabilidad 4/5 | Impacto 4/5

Compartir usuarios impide saber quién realizó una acción y dificulta revocar accesos cuando cambia el personal.

Crear usuarios individuales para recepción, administración y proveedores.

Estimacion orientativa por reglas; no es una medicion de incidentes.

PMS sin usuarios individuales

Prioridad Alto | Probabilidad 4/5 | Impacto 4/5

El sistema de gestión hotelera concentra reservas, datos de clientes y facturación. Si se usa con cuentas genéricas, se pierde trazabilidad.

Configurar usuarios individuales y perfiles por rol en el PMS.

Estimacion orientativa por reglas; no es una medicion de incidentes.

WiFi de huéspedes no separada

Prioridad Alto | Probabilidad 4/5 | Impacto 4/5

Los dispositivos de clientes podrían compartir red con sistemas internos del hotel, aumentando la superficie de ataque.

Separar la red de huéspedes de la red interna mediante VLAN o red independiente.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Terminales de pago no aislados

Prioridad Alto | Probabilidad 4/5 | Impacto 4/5

Los TPV y sistemas de pago deben estar separados de redes de clientes y de equipos no necesarios para reducir el riesgo sobre datos de pago.

Separar TPV y equipos de pago en una red propia o segmento restringido.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Acceso remoto de proveedores sin control suficiente

Prioridad Alto | Probabilidad 4/5 | Impacto 4/5

Los proveedores de PMS, mantenimiento o soporte pueden convertirse en una vía de entrada si sus accesos no se revisan ni se limitan.

Limitar accesos remotos por proveedor, horario, MFA y registro de actividad.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Continuidad sin plan

Prioridad Alto | Probabilidad 4/5 | Impacto 4/5

El cuestionario declara este control ausente. Debe validarse con evidencias del alojamiento.

Definir recuperacion de reservas, responsables y procedimientos alternativos.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Baja de empleados sin proceso de retirada de accesos

Prioridad Medio | Probabilidad 3/5 | Impacto 3/5

En negocios con personal temporal, un acceso olvidado puede seguir activo después de finalizar la relación laboral.

Crear una lista de baja para correo, PMS, llaves digitales y aplicaciones internas.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Cámaras o dispositivos IoT en la red principal

Prioridad Medio | Probabilidad 3/5 | Impacto 3/5

Cámaras, cerraduras inteligentes o domótica pueden tener vulnerabilidades y conviene aislarlos de recepción, administración y sistemas críticos.

Crear una red separada para CCTV, cerraduras, domótica y otros dispositivos IoT.

Estimacion orientativa por reglas; no es una medicion de incidentes.

No existe protocolo de brechas RGPD

Prioridad Medio | Probabilidad 3/5 | Impacto 3/5

Ante una fuga de datos personales, el hotel podría no reaccionar dentro de los plazos y obligaciones exigidos por el RGPD.

Definir un procedimiento de detección, evaluación y notificación de brechas.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Registro RGPD de tratamientos incompleto

Prioridad Medio | Probabilidad 3/5 | Impacto 3/5

Los alojamientos suelen tratar documentos de identidad, reservas y datos de contacto. Sin registro, es más difícil demostrar cumplimiento.

Documentar tratamientos, finalidades, bases legales, plazos de conservación y encargados.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Falta de formación frente a phishing

Prioridad Medio | Probabilidad 3/5 | Impacto 3/5

El personal de recepción y administración es un objetivo habitual para correos fraudulentos relacionados con reservas, pagos o proveedores.

Realizar formación básica y simulaciones periódicas de phishing.

Estimacion orientativa por reglas; no es una medicion de incidentes.

Plan de accion

Implantar copias de seguridad automáticas y mantener al menos una copia aislada.

Plazo: 0 dias | Prioridad: Critico | Estado: Completada

Responsable sugerido: Direccion y proveedor IT | Dificultad: media | Impacto: 5/5

Activar MFA en correo, PMS, paneles de reservas y cuentas administrativas.

Plazo: 30 dias | Prioridad: Alto | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: media | Impacto: 4/5

Crear usuarios individuales para recepción, administración y proveedores.

Plazo: 30 dias | Prioridad: Alto | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: media | Impacto: 4/5

Configurar usuarios individuales y perfiles por rol en el PMS.

Plazo: 30 dias | Prioridad: Alto | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: media | Impacto: 4/5

Separar la red de huéspedes de la red interna mediante VLAN o red independiente.

Plazo: 30 dias | Prioridad: Alto | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: media | Impacto: 4/5

Separar TPV y equipos de pago en una red propia o segmento restringido.

Plazo: 30 dias | Prioridad: Alto | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: media | Impacto: 4/5

Limitar accesos remotos por proveedor, horario, MFA y registro de actividad.

Plazo: 30 dias | Prioridad: Alto | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: media | Impacto: 4/5

Definir recuperacion de reservas, responsables y procedimientos alternativos.

Plazo: 30 dias | Prioridad: Alto | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: media | Impacto: 4/5

Crear una lista de baja para correo, PMS, llaves digitales y aplicaciones internas.

Plazo: 90 dias | Prioridad: Medio | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: baja | Impacto: 3/5

Crear una red separada para CCTV, cerraduras, domótica y otros dispositivos IoT.

Plazo: 90 dias | Prioridad: Medio | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: baja | Impacto: 3/5

Definir un procedimiento de detección, evaluación y notificación de brechas.

Plazo: 90 dias | Prioridad: Medio | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: baja | Impacto: 3/5

Documentar tratamientos, finalidades, bases legales, plazos de conservación y encargados.

Plazo: 90 dias | Prioridad: Medio | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: baja | Impacto: 3/5

Realizar formación básica y simulaciones periódicas de phishing.

Plazo: 90 dias | Prioridad: Medio | Estado: Pendiente

Responsable sugerido: Direccion y proveedor IT | Dificultad: baja | Impacto: 3/5

Politicas propuestas

Política de contraseñas y accesos

Reducir accesos no autorizados a sistemas críticos del alojamiento.

Alcance: Personal interno, dirección, recepción, administración y proveedores con acceso a sistemas.

Usuarios individuales - Alto

Cada empleado debe usar una cuenta propia para correo, PMS, reservas y herramientas internas.

Contraseñas robustas - Medio

Las contraseñas deben tener longitud suficiente, no reutilizarse y cambiarse si existe sospecha de filtración.

Doble factor obligatorio - Alto

Activar MFA en correo, PMS, paneles de reservas, administración y cuentas de proveedores.

Gestor de contraseñas - Medio

Implantar un gestor de contraseñas para evitar documentos compartidos o claves apuntadas en papel.

Evidencias: Listado de usuarios activos por sistema.; Capturas o exportación de MFA activado.; Registro de altas, bajas y cambios de permisos.

Revision: Trimestral o cuando cambie personal/proveedores.

Política de copias de seguridad

Garantizar recuperación ante ransomware, fallo técnico o borrado accidental.

Alcance: PMS, channel manager, facturación, documentos de huéspedes y ficheros de gestión.

Copias automáticas - Critico

Configurar copias de seguridad de reservas, facturación, documentación y ficheros operativos.

Copia aislada - Alto

Mantener al menos una copia separada del sistema principal para reducir impacto de ransomware.

Mejorar frecuencia - Alto

Pasar a copias semanales como mínimo, y diarias para información de reservas y facturación.

Pruebas de restauración - Medio

Realizar pruebas documentadas para comprobar que los datos pueden recuperarse.

Evidencias: Plan de copias.; Registro de ejecuciones.; Actas de prueba de restauración.

Revision: Mensual, con prueba de restauración al menos trimestral.

Política de uso de dispositivos

Proteger equipos que tratan datos de clientes y operación del hotel.

Alcance: Equipos corporativos, dispositivos de recepción, administración, TPV y dispositivos móviles.

Inventario de equipos - Medio

Mantener un listado de ordenadores, móviles, tablets, TPV y equipos usados por el alojamiento.

Bloqueo de pantalla - Medio

Activar bloqueo automático en equipos de recepción y administración.

Actualizaciones - Alto

Aplicar actualizaciones de sistema operativo, navegador y aplicaciones críticas.

Evidencias: Inventario de activos.; Registro de actualizaciones.; Estado de protección antivirus/EDR.

Revision: Mensual.

Política de red, WiFi e IoT

Reducir exposición entre clientes, dispositivos inteligentes y sistemas internos.

Alcance: Red interna, WiFi de huéspedes, TPV, CCTV, cerraduras inteligentes y domótica.

Red interna protegida - Medio

Limitar la red interna a equipos necesarios para la gestión del alojamiento.

Separación de WiFi de huéspedes - Alto

Separar la WiFi de clientes de la red interna mediante VLAN o red independiente.

Aislamiento de TPV - Alto

Mantener terminales de pago y equipos relacionados en segmento restringido.

Red separada para IoT/CCTV - Medio

Separar cámaras, cerraduras inteligentes y domótica de los equipos administrativos.

Evidencias: Diagrama simple de red.; Configuración de WiFi/VLAN.; Listado de dispositivos IoT/CCTV.

Revision: Semestral o al instalar nuevos dispositivos.

Política de respuesta a incidentes y RGPD

Responder de forma ordenada ante incidentes técnicos o brechas de datos personales.

Alcance: Dirección, recepción, administración, soporte IT y proveedores críticos.

Canal de aviso interno - Alto

Definir a quién avisar ante phishing, pérdida de dispositivo, ransomware o fuga de datos.

Plan de respuesta - Alto

Documentar pasos básicos: contener, avisar, preservar evidencias, recuperar y aprender.

Protocolo de brechas RGPD - Medio

Evaluar impacto, documentar hechos y preparar notificación si aplica.

Registro de tratamientos - Medio

Documentar datos tratados, finalidad, base legal, conservación y encargados.

Evidencias: Plan de respuesta a incidentes.; Registro de incidentes.; Registro RGPD de tratamientos y brechas.

Revision: Semestral y después de cada incidente.

Política de proveedores y accesos remotos

Controlar accesos externos a sistemas del alojamiento.

Alcance: Proveedores de PMS, channel manager, mantenimiento, soporte IT, marketing y sistemas de pago.

Listado de proveedores - Medio

Mantener una lista de proveedores con acceso a sistemas, datos o soporte técnico.

Control de acceso remoto - Alto

Limitar accesos remotos por usuario, horario, MFA y registro de actividad.

Evidencias: Listado de proveedores autorizados.; Contratos o acuerdos de tratamiento de datos.; Registro de accesos remotos.

Revision: Trimestral y al cambiar de proveedor.

Politica de teletrabajo

Reducir el riesgo operativo en Hotel Prueba Lanzarote.

Alcance: Personal que accede fuera del alojamiento

Procedimiento operativo - Alto

Acceder mediante canales corporativos con MFA; usar equipos actualizados y cifrados.

Evidencias: Procedimiento aprobado por direccion; Registro de revision y ejercicio practico

Revision: Trimestral y tras cambios relevantes.

Politica de correo y mensajeria

Reducir el riesgo operativo en Hotel Prueba Lanzarote.

Alcance: Recepcion, administracion y reservas

Procedimiento operativo - Alto

Verificar solicitudes de pagos por un segundo canal; usar correo corporativo y no enviar documentos de clientes por cuentas personales.

Evidencias: Procedimiento aprobado por direccion; Registro de revision y ejercicio practico

Revision: Trimestral y tras cambios relevantes.

Politica de PMS y reservas

Reducir el riesgo operativo en Hotel Prueba Lanzarote.

Alcance: PMS, channel manager y portales de reservas

Procedimiento operativo - Alto

Crear usuarios individuales, permisos minimos, revisar altas y bajas y registrar cambios sobre reservas.

Evidencias: Procedimiento aprobado por direccion; Registro de revision y ejercicio practico

Revision: Trimestral y tras cambios relevantes.

Politica de continuidad del negocio

Reducir el riesgo operativo en Hotel Prueba Lanzarote.

Alcance: Direccion, recepcion y proveedor IT

Procedimiento operativo - Alto

Mantener contactos de emergencia, prioridades de recuperacion, check-in manual y ensayo anual de perdida de conectividad.

Evidencias: Procedimiento aprobado por direccion; Registro de revision y ejercicio practico

Revision: Trimestral y tras cambios relevantes.

Orientacion y fuentes

AEPD - Facilita RGPD

Documentar tratamientos, encargados y medidas. Facilita se orienta a tratamientos de bajo riesgo; valorar cada caso.

https://www.aepd.es/guias-y-herramientas/herramientas/facilita-rgpd

INCIBE - Politicas para pymes

Establecer responsables, procedimientos, formacion y evidencias de seguridad.

https://www.incibe.es/empresas/herramientas/politicas

ISO - Familia ISO/IEC 27000

Gestionar riesgos, controles y mejora continua. Esta herramienta no realiza una certificacion ISO.

https://www.iso.org/standard/iso-iec-27000-family